

BÁO CÁO THỰC HÀNH

Thực hành Nhập môn Mạng máy tính

Lab 06: Triển khai mạng Doanh nghiệp SME & Đánh giá rủi ro

GVTH: Nguyễn Ngọc Trưởng

Ngày báo cáo: 29/05/2026

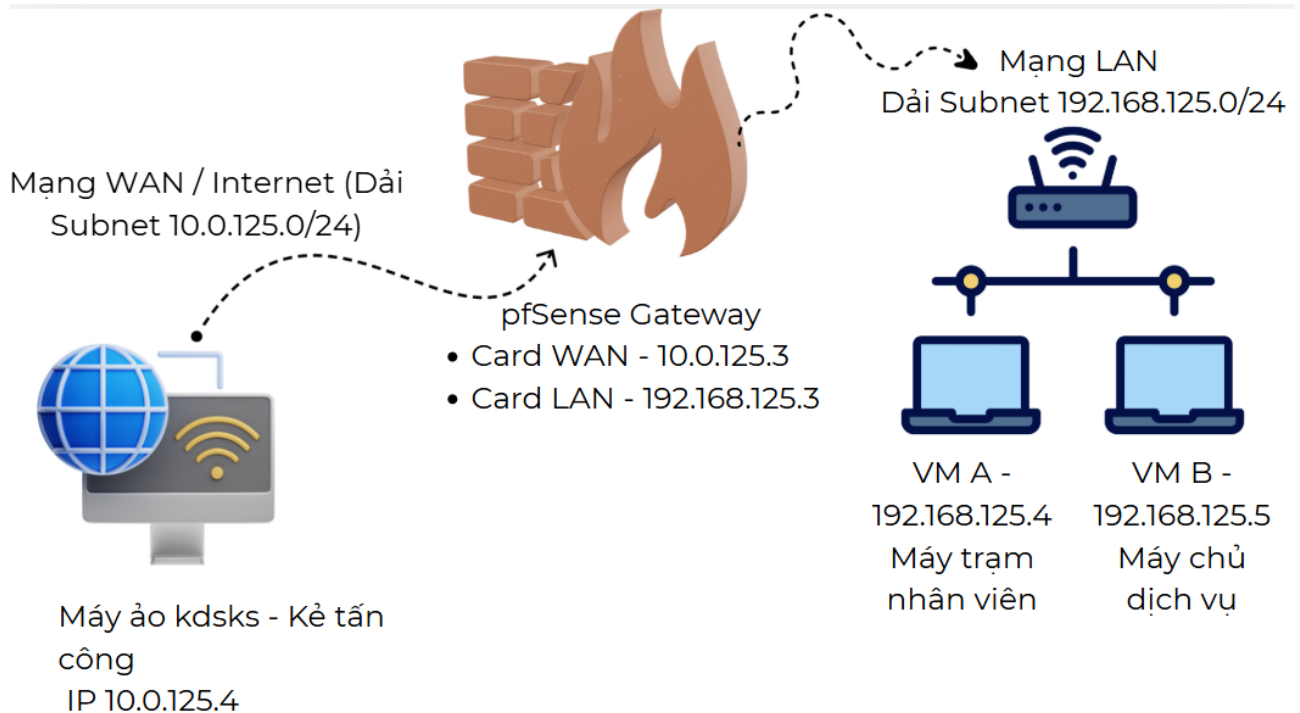
Nhóm 13 - NT101.Q22.1

THÔNG TIN CHUNG

MSSV	Họ và tên	Nội dung báo cáo	% công việc
23520536	Phạm Cao Minh Hoàng	Câu 1, câu 4	50%
24521388	Nguyễn Hoàng Phúc	Câu 2, câu 3	50%

1. Thiết kế và Vận hành Hạ tầng

a) Sơ đồ Kiến trúc Mạng:



b) Giải trình Bảng Định tuyến & Tường lửa:

- Triển khai tường lửa trên pfSense:
 - o Ingress
 - Thiết lập trên Firewall -> Rules -> WAN
 - Điều chỉnh các thông số
 - Source: Any
 - Destination: WAN subnets
 - **Business Logic:** Luật này thiết lập vùng bảo vệ tuyến đầu cho doanh nghiệp bằng triết lý "Zero Trust" đối với luồng dữ liệu từ bên ngoài. Trong mô hình SME hiện tại, công ty không cung cấp bất kỳ dịch vụ công khai nào trực tiếp ra ngoài Internet thông qua IP WAN. Do đó, việc chặn toàn bộ (Block All) các kết nối chủ động từ Internet hướng vào WAN subnets là bắt buộc. Điều này giúp hệ thống miễn nhiễm với các rủi ro bị dò quét cổng (Port Scanning), ngăn chặn triệt để nỗ lực xâm nhập mạng trái phép hoặc khai thác lỗ hổng từ xa.

Rules (Drag to Change Order)									
☐	States	Protocol	Source	Port	Destination	System alias details		Queue	S
☐	✗	0/0 B	IPv4 *	*	WAN subnets	WAN_NETWORK		none	
						• 10.0.125.0/24			
						Add		Add	

- o Egress
 - Thiết lập trên Firewall -> Rules -> LAN

- Điều chỉnh các thông số
 - Protocol: TCP/UDP
 - Source: Any
 - Destination From/To: AliasforPort (Tổng hợp các cổng cấu hình được chọn để chặn: 80, 443, 53, 22).
- Luật này áp dụng nguyên tắc "Least Privilege" đối với nhân viên nội bộ. Thay vì sử dụng một luật ngầm định cho phép mạng LAN truy cập tự do mọi nơi trên Internet, SysAdmin chỉ phê duyệt một danh sách Whitelist thông qua tập hợp cổng AliasforPort. Theo đó, máy tính nhân viên chỉ được phép sử dụng các dịch vụ thiết yếu phục vụ công việc:
 - **Port 80/443 (HTTP/HTTPS):** Duyệt web và truy cập các hệ thống phần mềm dạng web an toàn
 - **Port 53 (DNS):** Phục vụ phân giải tên miền.
 - **Port 22 (SSH):** Phục vụ các tác vụ quản trị, bảo trì từ xa an toàn qua kênh mã hóa. Mọi luồng dữ liệu sử dụng các cổng khác đều bị tường lửa từ chối ngầm (Implicit Deny), giúp giới hạn tối đa rủi ro lộ lọt dữ liệu hoặc kết nối tới các máy chủ điều khiển mã độc bên ngoài.

Rules (Drag to Change Order)										
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description
☒	✓ 1/1.58 MiB	*	*	*	LAN Address	80	Alias details			
☐	✓ 18/23.68 MiB	IPv4 TCP/UDP	*	*	*	AliasesforPort	80	443	53	22
☐	✓ 0/0 B	IPv4 *	*	*	nv201	*				

Value	Description
80	Entry added Fri, 29 May 2026 02:29:18 +0000
443	Entry added Fri, 29 May 2026 02:29:18 +0000
53	Entry added Fri, 29 May 2026 02:29:18 +0000
22	Entry added Fri, 29 May 2026 02:29:18 +0000

- Triển khai proxy:
 - Trên VM A, tiến hành cài đặt Squid và chỉnh sửa file config: Cho tạo danh sách chặn các tên miền mà 1 SysAdmin quy định, trong trường hợp của em là tên miền facebook.com bằng các câu lệnh như dưới:

```
GNU nano 4.8 /etc/squid/squid.conf
acl Safe_ports port 443      # https
acl Safe_ports port 70       # gopher
acl Safe_ports port 210      # wais
acl Safe_ports port 1025-65535 # unregistered ports
acl Safe_ports port 280      # http-mgmt
acl Safe_ports port 488      # gss-http
acl Safe_ports port 591      # filemaker
acl Safe_ports port 777      # multiling http
acl CONNECT method CONNECT

acl blocked_sites dstdomain .facebook.com
http_access deny blocked_sites
# TAG: proxy_protocol_access
# Determine which client proxies can be trusted to provide correct
# information regarding real client IP address using PROXY protocol.
#
# Requests may pass through a chain of several other proxies
# before reaching us. The original source details may be sent in:
# * HTTP message Forwarded header, or
# * HTTP message X-Forwarded-For header, or
[ Search Wrapped ]
^G Get Help  ^O Write Out ^W Where Is  ^K Cut Text  ^J Justify   ^C Cur Pos
^X Exit      ^R Read File ^\ Replace   ^U Paste Text ^T To Spell  ^_ Go To Line
```

- Áp dụng Proxy cho trình duyệt hiện tại:

Configure Proxy Access to the Internet

☐ No proxy

☐ Auto-detect proxy settings for this network

☐ Use system proxy settings

☒ Manual proxy configuration

HTTP Proxy Port

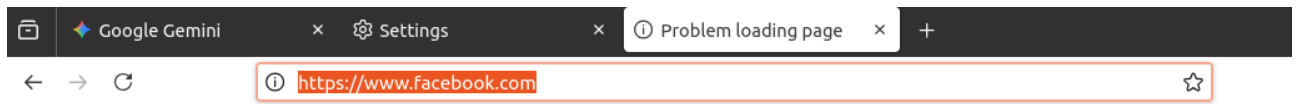
☒ Also use this proxy for HTTPS

HTTPS Proxy Port

SOCKS Host Port

☐ SOCKS v4 ☒ SOCKS v5

- Kết quả thu được cho thấy Proxy chặn truy cập vào trang facebook.com thành công:



The proxy server is refusing connections

Firefox is configured to use a proxy server that is refusing connections.

Error code: 403 Forbidden

- Check the proxy settings to make sure that they are correct.
- Contact your network administrator to make sure the proxy server is working.

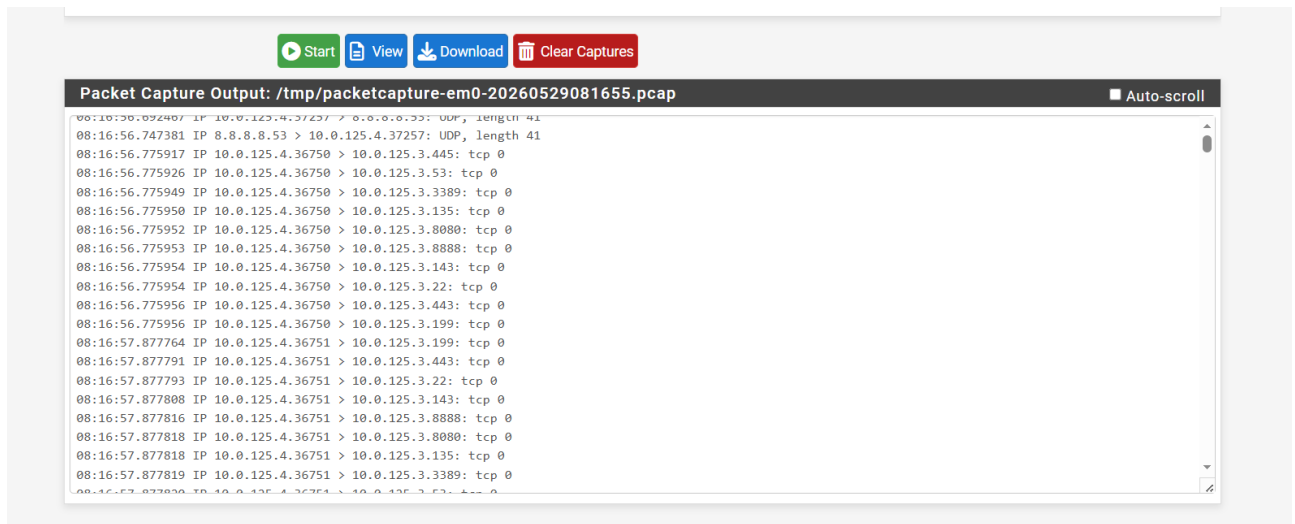
Try Again

2. Tự Kiểm toán Vòng đai

- Sử dụng máy ảo “ksdk” đặt ngoài internet chạy Nmap quét vào pfSense WAN:

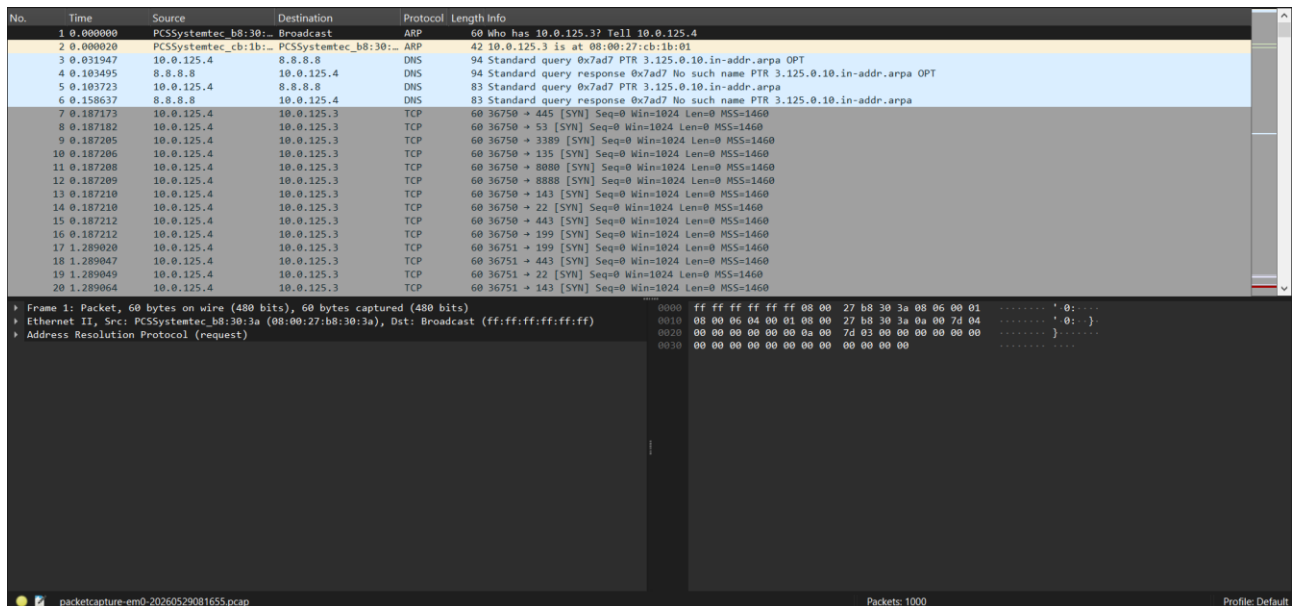
```
pau@pau-VirtualBox:~$ sudo nmap -sS -Pn 10.0.125.3
Starting Nmap 7.80 ( https://nmap.org ) at 2026-05-29 15:16 +07
Nmap scan report for 10.0.125.3
Host is up (0.00059s latency).
All 1000 scanned ports on 10.0.125.3 are filtered
MAC Address: 08:00:27:CB:1B:01 (Oracle VirtualBox virtual NIC)
```

- Dựa trên thông báo Nmap, ta biết được Nmap đã ném 1000 gói tin SYN vào tường lửa, nhưng không nhận lại được bất kỳ lời hồi đáp nào.



- Trong toàn bộ danh sách trên pfSense, không hề có dòng nào phản hồi ngược lại từ 10.0.125.3 > 10.0.125.4. Điều này chứng tỏ Firewall đã thực thi xuất sắc luật Ingress (Block All chiều vào).

c) Minh chứng Kiểm toán vành đai:



- Kết quả thu được dựa trên nội dung phân tích từ phần mềm Wireshark cho kết quả tương tự: Drop các gói Syn

3. Phân tích rủi ro

- Kích hoạt dịch vụ nhận kết nối SSH trên máy "kdsks":

```
pau@pau-VirtualBox:~$ sudo systemctl start ssh
```

- Thiết lập đường hầm Reverse SSH truyền ngược ra ngoài Internet tới máy ksdks trên VM B:

```
^Cpau@pau-VirtualBox:~$ ssh -N -R 2223:localhost:22 pau@10.0.125.4
pau@10.0.125.4's password:
```

- Trên kdsks: Thiết lập lại cấu hình proxy trên trình duyệt, tạo Dynamic Port Forwarding (SOCKS Proxy) tại cổng 9050 thông qua đường hầm vừa nhận:

☒ Manual proxy configuration

HTTP Proxy Port

☐ Also use this proxy for **HTTPS**

HTTPS Proxy Port

SOCKS Host Port

☐ SOCKS v4 ☒ SOCKS v5

☐ Automatic proxy configuration URL

No proxy for

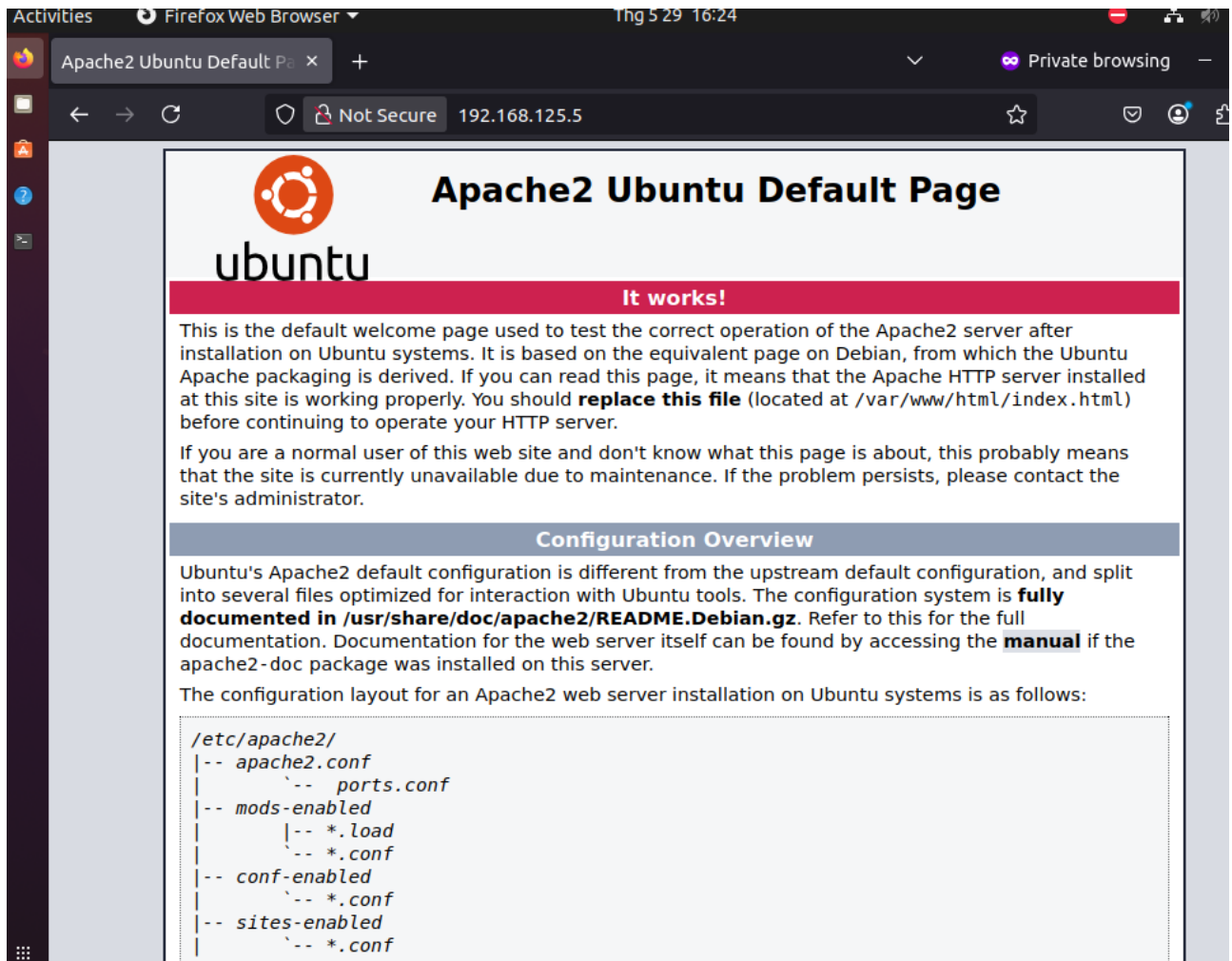
Example: .mozilla.org, .net.nz, 192.168.1.0/24

Connections to localhost, 127.0.0.1/8, and ::1 are never proxied.

- Thay vì sử dụng IP 192.168.125.4 thì sử dụng địa chỉ 127.0.0.1 thay thế bởi địa chỉ kia chắc chắn sẽ bị tường lửa từ chối truy cập.
- Thực hiện khởi tạo dịch vụ apache2 trên VMB và tiến hành kết nối từ máy ảo "kdsks" đến VM B:

```
pau@pau-VirtualBox:~$ sudo systemctl start apache2
pau@pau-VirtualBox:~$
```

- Kết nối thành công



d) Phân tích Cơ chế vượt rào:

- Bản chất của Kênh truyền thông ẩn (Covert Channel):
 - o Bản chất của kỹ thuật Tunneling là **Sự đóng gói – encapsulation**
 - o Mục đích thật của Kẻ tấn công là lướt web (giao thức HTTP - cổng 80) trên máy chủ nội bộ.
 - o Nhưng thay vì gửi thẳng gói tin HTTP, Kẻ tấn công nhét gói tin HTTP đó vào bên trong một phong bì thư mang tên **SSH (cổng 22)**.
 - o Kênh truyền thông này được gọi là "ẩn" vì luồng dữ liệu thực sự (HTTP) tàng hình hoàn toàn bên trong lớp vỏ bọc hợp lệ (SSH).
- Tại sao Tường lửa (Firewall) lại bị "qua mặt" một cách dễ dàng?
 - o **Chủ quan:** Các quản trị viên thường thiết lập Firewall chặn cực kỳ gắt gao chiều từ Internet đi vào (Ingress/Inbound), nhưng lại mở toang chiều từ mạng LAN đi ra Internet (Egress/Outbound) bằng một luật Allow LAN to ANY để nhân viên có thể lướt web bình thường. Trong kỹ thuật này, máy Nạn nhân (VM B) nằm ở bên trong LAN đã **chủ động** khởi tạo kết nối SSH đi ra ngoài máy Kẻ tấn công. Firewall nhìn thấy một yêu cầu từ "người nhà" muốn đi ra ngoài, nó lập tức ghi nhận trạng thái (Stateful) và mở cửa cho đi, đồng thời cho phép luồng dữ liệu phản hồi chạy ngược lại vào trong.

- **Kẻ hở trong thuật toán:** Firewall truyền thống (L4 Firewall) chỉ kiểm tra được IP nguồn, IP đích và Port. Nó nhìn thấy luồng dữ liệu chạy qua Port 22, nó gắn nhãn: *"Đây là luồng SSH an toàn"*. Do đặc tính của SSH là mã hóa toàn bộ Payload (nội dung), Firewall hoàn toàn bị "mù", không thể đọc được bên trong cái vỏ bọc SSH đó thực chất đang chứa các gói tin lướt Web SOCKS Proxy hay dữ liệu bị đánh cắp.
- Việc cần làm cho các SysAdmin:
 - Tuyệt đối không dùng luật "mở toang" cho chiều đi ra Internet đối với vùng chứa máy chủ (Server/DMZ). Chỉ cho phép các port cực kỳ cụ thể (như 80, 443 cho update hệ điều hành) và chỉ trỏ tới đúng các IP đích cần thiết.
 - Nâng cấp lên Tường lửa thế hệ mới (Next-Gen Firewall). DPI có khả năng phân tích hành vi của gói tin. Dù đi qua port 443 hay 22, nếu NGFW phát hiện hành vi truyền tải dữ liệu giống SOCKS Proxy hoặc VPN, nó sẽ tự động Drop luồng dữ liệu đó.
 - Triển khai các hệ thống giám sát cảnh báo (như Zabbix, Wazuh hoặc EDR) trực tiếp trên các máy chủ nội bộ. Nếu có một câu lệnh bất thường như ssh -R hoặc ssh -D được gõ ra, hoặc phát hiện một tiến trình mạng giữ kết nối liên tục ra bên ngoài, hệ thống sẽ gửi Trigger báo động cho SysAdmin ngay lập tức để ngắt mạng cô lập máy đó.

4. Kiểm toán rủi ro sâu

- Tiến hành thao tác trên giao diện Nessus. Tạo 1 Basic Network Scan với các thông tin như hình dưới, thực hiện quét IP của Metasploitable 2 – VM B (192.168.125.5)

The screenshot shows the Nessus web interface with the 'Plugins' tab selected. The configuration form is as follows:

Name	Lab06
Description	
Folder	My Scans
Targets	192.168.125.5
Upload Targets	Add File

e) Báo cáo Tình trạng Lỗ hổng (Vulnerability Summary)

- Tổng quan:
- Thu được 2 lỗ hổng medium chiếm 5% và 95% còn lại thuộc về việc rò rỉ thông tin cấu hình.

Sev	CVSS	VPR	EPSS	NFamily	Count	
MEDIUM	6.5			UiMisc.	1	
MEDIUM	5.0 *			mService detection	1	
INFO	...	...	...	Web Servers	5	
INFO	...	...	...	General	2	
INFO	...	...	...	Misc.	2	
INFO	...	...	...	Service detection	2	
INFO				ScService detection	5	
INFO				NiPort scanners	4	
INFO				AiWeb Servers	1	
INFO				BiGeneral	1	
INFO				CcGeneral	1	

Scan Details

Policy: Basic Network Scan
 Status: Completed
 Severity Base: CVSS v3.0
 Scanner: Local Scanner
 Start: Today at 7:01 PM
 End: Today at 7:16 PM
 Elapsed: 15 minutes

Vulnerabilities

Medium: 5%

● Critical
● High
● Medium
● Low
● Info

- Lỗ hổng 1: Unencrypted Telnet Server
 - o **Mức độ rủi ro:** Medium (Điểm CVSS v3.0: 6.5).
 - o **Mô tả**
 - Nessus phát hiện máy chủ đang chạy dịch vụ Telnet mở qua cổng 23/TCP.
 - Toàn bộ quá trình giao tiếp qua Telnet (bao gồm tên đăng nhập, mật khẩu và các câu lệnh quản trị) đều được truyền tải dưới dạng văn bản rõ mà không có bất kỳ cơ chế mã hóa nào.
 - Nếu một nhân viên nội bộ hoặc kẻ tấn công sử dụng kỹ thuật tấn công trung gian (Man-in-the-Middle) để nghe lén (eavesdrop) lưu lượng mạng, chúng có thể dễ dàng đánh cắp thông tin đăng nhập nhạy cảm.
 - Kết quả quét cũng làm lộ thông tin hệ điều hành (Banner Grabbing) là Ubuntu 20.04.6 LTS – trùng khớp với thông tin mà em đang sử dụng.
- ⇒ **Đề xuất khắc phục:** Vô hiệu hóa hoàn toàn dịch vụ Telnet trên máy chủ nội bộ và chuyển sang sử dụng giao thức SSH để đảm bảo mọi phiên đăng nhập và luồng dữ liệu đều được mã hóa an toàn.

MEDIUM Unencrypted Telnet Server

Description

The remote host is running a Telnet server over an unencrypted channel.

Using Telnet over an unencrypted channel is not recommended as logins, passwords, and commands are transferred in cleartext. This allows a remote, man-in-the-middle attacker to eavesdrop on a Telnet session to obtain credentials or other sensitive information and to modify traffic exchanged between a client and server.

SSH is preferred over Telnet since it protects credentials from eavesdropping and can tunnel additional data streams such as an X11 session.

Solution

Disable the Telnet service and use SSH instead.

Output

```
Nessus collected the following banner from the remote Telnet server :

----- snip -----
Ubuntu 20.04.6 LTS
pau-VirtualBox login:
----- snip -----

To see debug logs, please visit individual host
```

Port ▲	Hosts
23 / tcp / telnet	192.168.125.5

Plugin Details

Severity: Medium
ID: 42263
Version: 1.15
Type: remote
Family: Misc.
Published: October 27, 2009
Modified: January 16, 2024

Risk Information

Risk Factor: Medium
CVSS v3.0 Base Score: 6.5
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
CVSS v2.0 Base Score: 5.8
CVSS v2.0 Vector: CVSS2#AV:N/AC:M/Au:N/C:P/I:P/A:N

- **Lỗi hỏng 2: mDNS Detection (Remote Network)**
 - **Mức độ rủi ro: Medium.**
 - **Mô tả:**
 - Hệ thống đang mở cổng 5353/UDP chạy giao thức mDNS
 - Dịch vụ này cho phép bất kỳ thực thể nào trong mạng thực hiện truy vấn để thu thập thông tin định danh của máy chủ từ xa.
 - Các thông tin bị rò rỉ bao gồm loại hệ điều hành, phiên bản chính xác, danh sách các dịch vụ đang chạy và tên máy (hostname được ghi nhận là pau-VirtualBox-2.local).
 - Kẻ tấn công thường lạm dụng giao thức này trong giai đoạn thu thập thông tin để lập bản đồ mạng và tìm kiếm các phương thức tấn công đặc thù nhắm vào hệ điều hành đang dùng.
- ⇒ **Đề xuất khắc phục:** Thiết lập cấu hình lọc (filter) chặn luồng dữ liệu đi vào cổng UDP 5353 trên tường lửa cục bộ (như iptables/UFW) của Ubuntu, hoặc cấu hình chặn mDNS trực tiếp trên tường lửa pfSense nếu không có nhu cầu sử dụng tính năng khám phá dịch vụ tự động trong mạng LAN.

MEDIUM

mDNS Detection (Remote Network)

< >

Plugin Details

Severity: Medium

ID: 12218

Version: 1.27

Type: remote

Family: Service detection

Published: April 28, 2004

Modified: June 28, 2021

Description

The remote service understands the Bonjour (also known as ZeroConf or mDNS) protocol, which allows anyone to uncover information from the remote host such as its operating system type and exact version, its hostname, and the list of services it is running.

This plugin attempts to discover mDNS used by hosts that are not on the network segment on which Nessus resides.

Solution

Filter incoming traffic to UDP port 5353, if desired.

Risk Information

Risk Factor: Medium

CVSS v2.0 Base Score: 5.0

CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N

Output

Nessus was able to extract the following information :

- mDNS hostname : pau-VirtualBox-2.local.

To see debug logs, please visit individual host

Port ▲	Hosts
5353 / udp / mdns	192.168.125.5

HẾT